

Zadanie 1: Gość w sieci domowej - Analiza ryzyka

1. Zidentyfikowane zagrożenia

Zagrożenie 1: Nieautoryzowany dostęp do zasobów sieciowych

- Gość może uzyskać dostęp do dysku NAS z prywatnymi backupami, komputerów oraz drukarki
- Możliwość kradzieży, modyfikacji lub usunięcia wrażliwych danych osobistych i dokumentów

Zagrożenie 2: Infekcja malware i rozprzestrzenianie się w sieci

- Urządzenie gościa może być zainfekowane wirusami, trojanami lub ransomware
- Malware może się rozprzestrzenić na inne urządzenia w sieci lokalnej poprzez współdzielone zasoby lub luki w zabezpieczeniach

Zagrożenie 3: Sniffing i przechwytywanie ruchu sieciowego

- Gość może używać narzędzi do monitorowania ruchu w sieci lokalnej
- Możliwość przechwycenia niezaszyfrowanej komunikacji, haseł lub innych wrażliwych informacji

2. Ocena ryzyka według macierzy 3x3

Prawdopodobieństwo: Średnie (M)

- Nie znamy gościa osobiście
- Nie znamy stanu bezpieczeństwa jego urządzenia
- Statystycznie wiele urządzeń konsumenckich ma słabe zabezpieczenia lub nieaktualne oprogramowanie

Wpływ: Wysoki (H)

- Potencjalna utrata prywatnych danych i backupów
- Możliwość kompromitacji całej sieci domowej
- Krytyczne dane osobiste i dokumenty są w zasięgu

Poziom ryzyka według macierzy:  **WYSOKIE** (przecięcie Średniego prawdopodobieństwa i Wysokiego wpływu = Wysokie ryzyko)

3. Decyzja dotycząca postępowania z ryzykiem

Wybrana strategia: MITYGACJA

Uzasadnienie: Całkowite unikanie (odmowa dostępu) może być nieuprzejme wobec gościa domownika, a akceptacja naraża nas na zbyt wysokie ryzyko. Mitygacja pozwala zapewnić gościowi dostęp do Internetu przy jednoczesnym zabezpieczeniu naszych zasobów.

4. Konkretny kroki mitygacyjne

Rozwiązanie techniczne: Sieć gościnna (Guest Network)

Krok 1: Konfiguracja sieci gościnnej w routerze

- Zalogować się do panelu administracyjnego routera (zazwyczaj 192.168.1.1 lub 192.168.0.1)
- Włączyć funkcję "Guest Network" / "Sieć gościnna"
- Ustawić oddzielny SSID (np. "WiFi_Goście")
- Ustawić hasło WPA2/WPA3 dla sieci gościnnej

Krok 2: Izolacja sieci (kluczowe zabezpieczenie)

- Włączyć opcję "AP Isolation" / "Client Isolation" / "Izolacja gości"
- Włączyć opcję "Disable access to local network" / "Blokada dostępu do sieci lokalnej"
- To uniemożliwi urządzeniom w sieci gościnnej komunikację z urządzeniami w sieci głównej (LAN)

Krok 3: Dodatkowe zabezpieczenia

- Ograniczyć przepustowość dla sieci gościnnej (QoS) - opcjonalnie
- Ustawić limit czasu działania sieci gościnnej (np. 24h)
- Włączyć logowanie połączeń - dla ewentualnej analizy w razie problemów

Krok 4: Weryfikacja zabezpieczeń

- Po podłączeniu gościa, przetestować czy nie ma dostępu do:
 - Dysku NAS (próba pingowania adresu IP NAS)
 - Drukarki sieciowej
 - Innych urządzeń w sieci lokalnej
- Upewnić się, że Internet działa poprawnie

Alternatywne rozwiązanie (jeśli router nie obsługuje sieci gościnnej):

Użycie hotspota mobilnego:

- Utworzyć hotspot WiFi ze smartfona
- Udostępnić gościowi dostęp przez telefon zamiast przez sieć domową
- Całkowita izolacja od sieci domowej

Podsumowanie

Ocena ryzyka:  Wysokie

Strategia: Mitygacja

Rozwiązanie: Sieć gościnna z izolacją od LAN

Efekt: Ryzyko zostaje zredukowane do poziomu  Niskiego, ponieważ:

- Prawdopodobieństwo ataku pozostaje średnie, ale
- Wpływ zostaje znacząco ograniczony (brak dostępu do krytycznych zasobów)
- Nowy poziom ryzyka: Średnie prawdopodobieństwo × Niski wpływ = 🟡
Średnie/Niskie

Zadanie 2: Krytyczna podatność routera (EoL) - Analiza i mitygacja

1. Analiza obecnego stanu - Ocena ryzyka

Charakterystyka zagrożenia:

- **CVSS 10.0** - maksymalny poziom krytyczności
- **Remote Code Execution (RCE)** z uprawnieniami root
- **Wektor ataku:** Zdalny, przez Internet (publiczny adres IP)
- **Wymagana interakcja:** Brak (atak może być w pełni automatyczny)
- **Podatność w protokole ICMP** (ping)

Ocena według macierzy 3x3:

Prawdopodobieństwo: WYSOKIE (H)

- Podatność jest publicznie znana (disclosed)
- CVSS 10.0 oznacza łatwość eksploatacji
- Automatyczne skanery i boty już prawdopodobnie szukają takich urządzeń
- Brak łatki = urządzenie pozostanie podatne na zawsze
- Publiczny adres IP jest łatwy do znalezienia (automatyczne skanowanie przestrzeni IPv4)

Wpływ: WYSOKI (H)

- Pełna kompromitacja routera (dostęp root)
- Atakujący może:
 - Przechwytywać cały ruch sieciowy (Man-in-the-Middle)
 - Przekierowywać ruch do złośliwych serwerów (DNS hijacking)
 - Wykorzystać router jako punkt wejścia do sieci lokalnej
 - Używać urządzenia w botnetach (DDoS)
 - Wykraść dane logowania, hasła, dane bankowe
 - Zainstalować backdoora dla trwałego dostępu

Poziom ryzyka według macierzy: 🟡 **WYSOKIE** (Wysokie prawdopodobieństwo × Wysoki wpływ = **KRYTYCZNE/WYSOKIE**)

Wniosek: Urządzenie w obecnej konfiguracji stanowi **krytyczne zagrożenie** i wymaga natychmiastowej mitygacji.

2. Plan naprawczy - Mitygacja techniczna

Strategia: Wielowarstwowa obrona (Defense in Depth)

Ponieważ nie możemy wyeliminować podatności (brak łatki), musimy **zablokować wektor ataku** - czyli dostęp z Internetu do routera.

KROK 1: Wyłączenie odpowiedzi ICMP na interfejsie WAN ★ KLUCZOWE

Cel: Zneutralizowanie bezpośredniego wektora ataku

Implementacja:

```
# Logowanie do routera przez SSH lub interfejs webowy  
ssh root@192.168.1.1
```

```
# Wyłączenie odpowiedzi na ping z zewnątrz (WAN)  
# Metoda zależy od systemu routera:
```

```
# Dla routerów z iptables (Linux):  
iptables -A INPUT -i ppp0 -p icmp --icmp-type echo-request -j DROP  
# lub dla interfejsu eth0.2 (zależy od konfiguracji ISP)  
iptables -A INPUT -i eth0.2 -p icmp --icmp-type echo-request -j DROP
```

```
# Zapisanie reguł na stałe  
iptables-save > /etc/iptables/rules.v4
```

```
# Dla routerów z firewall'em UCI (OpenWrt):  
uci set firewall.@defaults[0].drop_invalid='1'  
uci set firewall.@zone[1].input='DROP' # zona WAN  
uci commit firewall  
/etc/init.d/firewall restart
```

Weryfikacja:

```
# Z zewnętrznego hosta (np. telefon na LTE):  
ping [twój_publiczny_IP] # Powinno timeout / no response
```

KROK 2: Wyłączenie zarządzania z WAN

Cel: Blokada wszelkich portów zarządzających dostępnych z Internetu

Implementacja:

```
# Zablokowanie portów administracyjnych z WAN:
```

Interfejs webowy (HTTP/HTTPS)

```
iptables -A INPUT -i ppp0 -p tcp --dport 80 -j DROP
```

```
iptables -A INPUT -i ppp0 -p tcp --dport 443 -j DROP
```

```
iptables -A INPUT -i ppp0 -p tcp --dport 8080 -j DROP
```

SSH

```
iptables -A INPUT -i ppp0 -p tcp --dport 22 -j DROP
```

Telnet (jeśli włączony)

```
iptables -A INPUT -i ppp0 -p tcp --dport 23 -j DROP
```

TR-069 (zarządzanie ISP)

```
iptables -A INPUT -i ppp0 -p tcp --dport 7547 -j DROP
```

UPnP (często wykorzystywane)

```
iptables -A INPUT -i ppp0 -p udp --dport 1900 -j DROP
```

Zapis konfiguracji

```
iptables-save > /etc/iptables/rules.v4
```

Alternatywnie - przez interfejs webowy:

- **Administration → Remote Management → Disable**
 - **Firewall → WAN Rules → Block all inbound connections**
-

KROK 3: Implementacja zasady Default Deny na WAN

Cel: Zablokowanie wszystkich nieznanych połączeń przychodzących

Polityka DEFAULT DROP dla WAN

```
iptables -P INPUT DROP
```

```
iptables -P FORWARD ACCEPT # Zachowanie routingu dla LAN
```

```
iptables -P OUTPUT ACCEPT # Zachowanie komunikacji wychodzącej
```

Zezwolenie tylko na:

1. Ustanowione połączenia (odpowiedzi na nasze żądania)

```
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
```

2. Loopback

```
iptables -A INPUT -i lo -j ACCEPT
```

```
# 3. LAN (jeśli interfejs br-lan/eth1)
```

```
iptables -A INPUT -i br-lan -j ACCEPT
```

```
# Wszystko inne z WAN = DROP (domyślnie)
```

KROK 4: Wyłączenie niepotrzebnych usług

Cel: Minimalizacja powierzchni ataku

```
# Sprawdzenie działających usług
```

```
netstat -tulpn
```

```
# Wyłączenie niepotrzebnych demonów:
```

```
/etc/init.d/telnetd stop
```

```
/etc/init.d/telnetd disable
```

```
/etc/init.d/dropbear stop    # jeśli SSH nie jest używany
```

```
/etc/init.d/dropbear disable
```

```
# Wyłączenie UPnP (jeśli nie jest potrzebny)
```

```
/etc/init.d/miniupnpd stop
```

```
/etc/init.d/miniupnpd disable
```

```
...
```

```
**Przez interfejs webowy:**
```

```
- Services → UPnP → **Disable**
```

```
- Services → SSH → **Disable** (jeśli nie używany)
```

```
---
```

```
### **KROK 5: Dodatkowa warstwa - NAT/Firewall przed routerem ISP**
```

```
**Rozwiązanie długoterminowe:** Dodanie własnego routera
```

```
...
```

```
Internet → Router ISP (tryb bridge/modem) → Własny router → Sieć domowa
```

```
...
```

```
**Implementacja:**
```

1. Zakup bezpiecznego routera (aktualnie wspierany, np. ASUS, TP-Link z aktualnymi firmware)
2. Konfiguracja routera ISP w ****tryb bridge**** lub ****modem only****:
...

Advanced Settings → WAN → Connection Type → Bridge Mode

3. Podłączenie własnego routera, który obsługuje:

- **Automatyczne aktualizacje bezpieczeństwa**
- **Nowoczesny firewall**
- **Izolację routera ISP od Internetu**

Rezultat: Router ISP nie jest bezpośrednio wystawiony na Internet

KROK 6: Monitoring i wykrywanie

Cel: Wczesne wykrycie próby ataku

Włączenie logowania firewall'a

```
iptables -A INPUT -i ppp0 -j LOG --log-prefix "WAN-DROP: " --log-level 4
```

Monitorowanie logów

```
tail -f /var/log/messages | grep "WAN-DROP"
```

Automatyczne alerty (opcjonalnie)

Skrypt sprawdzający nietypową aktywność

Podsumowanie konfiguracji - Checklist

- **ICMP echo-request zablokowany na WAN** (główny wektor)
- **Zarządzanie z WAN wyłączone** (HTTP/HTTPS/SSH/Telnet)
- **Polityka Default Deny na INPUT** (tylko ESTABLISHED,RELATED)
- **Niepotrzebne usługi wyłączone** (UPnP, Telnet)
- **Rozważenie trybu bridge + własny router** (długoterminowe)

Weryfikacja skuteczności mitygacji

Test 1: Skanowanie z zewnątrz

Z zewnętrznego hosta:

```
nmap -Pn -sV [twój_publiczny_IP]
```

Wynik: All ports filtered / no response

```
ping [twój_publiczny_IP]
```

Wynik: Request timeout

Test 2: Funkcjonalność Internetu

Z urządzenia w sieci lokalnej:

ping 8.8.8.8 # Powinno działać

curl https://google.com # Powinno działać

Ostateczna ocena ryzyka po mitygacji

Nowe prawdopodobieństwo: Niskie (L)

- Wektor ataku (ICMP z WAN) został zablokowany
- Brak portów dostępnych z Internetu
- Atakujący nie może wykorzystać podatności

Wpływ: Wysoki (H) - podatność nadal istnieje, ale jest niedostępna

Nowy poziom ryzyka: 🟡 ŚREDNIE (Niskie prawdopodobieństwo × Wysoki wpływ)

Ryzyko rezydualne:

- Możliwość ataku z sieci lokalnej (jeśli LAN zostanie skompromitowany)
- Rekomendacja długoterminowa: Wymiana routera na wspierany model w ciągu 1-3 miesięcy

Dodatkowe zalecenia

1. Nie udostępniać portu 22/80/443 przez port forwarding
2. Wyłączyć WPS (jeśli dostępny)
3. Zmienić domyślne hasło WiFi i admin
4. Rozważyć VPN dla dostępu zdalnego zamiast bezpośredniego zarządzania
5. Planować wymianę urządzenia - mitygacja nie zastępuje łatki

Zadanie 3: Współdzielone konto w księgowości - Analiza ryzyka biznesowego

1. Analiza Ryzyka - Brak rozliczalności (Accountability)

Zidentyfikowane zagrożenia:

Zagrożenie 1: Niemożność ustalenia sprawcy defraudacji

- Jeśli dojdzie do kradzieży środków lub manipulacji finansowej, niemożliwe będzie ustalenie, która z 5 osób dokonała nieprawidłowej operacji
- Wszystkie działania są przypisane do jednego użytkownika "ksiegowosc@firma.pl"
- Brak ścieżki audytu (audit trail) uniemożliwia śledztwo wewnętrzne

Zagrożenie 2: Utrudnienie śledztwa prawnego i dowodowego

- W przypadku postępowania karnego lub cywilnego, brak jednoznacznych dowodów może:
 - Uniemożliwić skazanie winnej osoby
 - Narazić niewinnych pracowników na podejrzenia
 - Doprowadzić do uniewinnienia sprawcy z powodu "reasonable doubt"
 - Spowodować odrzucenie dowodów elektronicznych przez sąd

Zagrożenie 3: Niewykrywalność błędów i sabotażu

- Przypadkowe lub celowe usunięcie danych finansowych
- Brak możliwości określenia, kto i kiedy wprowadził błędne dane
- Niemożność przywrócenia odpowiedzialności za błędy księgowe

Zagrożenie 4: Łamanie zasad segregacji obowiązków (SoD)

- Jedna osoba może zainicjować, zatwierdzić i zaksięgować transakcję
- Brak kontroli wewnętrznej wymaganej przez standardy audytu (SOX, ISO 27001)
- Ryzyko odrzucenia audytu zewnętrznego

Zagrożenie 5: Problemy HR i prawne

- Niemożność udowodnienia winy konkretnego pracownika przy zwolnieniu
- Potencjalne roszczenia pracowników o bezpodstawne oskarżenia
- Brak podstaw do dochodzenia odszkodowań od sprawcy

Scenariusz incydentu:

Dzień 1: Ktoś z 5 osób przelewa 50,000 PLN na prywatne konto

Dzień 5: Audyt wykrywa brakującą kwotę

Śledztwo:

- Log systemowy: "ksiegowosc@firma.pl wykonał przelew"
- Hasło znało 5 osób
- Nie ma zapisów, kto był zalogowany w tym czasie
- Kamery pokazują, że wszyscy byli w biurze
- Brak możliwości ustalenia sprawcy

Rezultat:

- Firma traci 50,000 PLN
- Nie można nikogo oskarżyć
- Sprawca unika odpowiedzialności
- Atmosfera w zespole jest zrujnowana (wszyscy są podejrzani)

Ocena ryzyka - Brak rozliczalności:

Prawdopodobieństwo: ŚREDNIE (M)

- Księgowość ma dostęp do środków finansowych (motywacja)
- 5 osób = 5 razy większe prawdopodobieństwo niż przy 1 osobie
- Brak kontroli sprzyja pokusie
- Statystyki: 42% przestępstw gospodarczych to fraud wewnętrzny (ACFE 2024)

Wpływ: WYSOKI (H)

- Potencjalna utrata znacznych kwot (dziesiątki/setki tysięcy PLN)
- Niemożność odzyskania środków
- Uszkodzenie reputacji firmy
- Koszty śledztwa i postępowania prawnego
- Utrata zaufania zespołu i klientów
- Możliwe konsekwencje regulacyjne (KNF, UOKiK)

Poziom ryzyka: ● WYSOKIE

2. Analiza Ryzyka - Łamanie licencji

Zidentyfikowane zagrożenia:

Zagrożenie 1: Kary umowne od dostawcy SaaS

- Większość umów SaaS zawiera klauzule o karach za łamanie licencji
- Typowe kary: 150-300% wartości nielegalnie używanych licencji
- Przykład: Jeśli licencja = 500 PLN/user/rok, kara może wynieść:
 - 4 dodatkowych użytkowników × 500 PLN × 300% = 6,000 PLN za rok
 - Za 3 lata naruszenia: 18,000 PLN + odsetki

Zagrożenie 2: Audyt licencyjny

- Dostawcy SaaS mają prawo do audytu wykorzystania oprogramowania
- Wykrycie naruszenia poprzez:
 - Logi dostępu (różne IP, różne czasy logowania)
 - Analitykę użytkowania (5 osób pracuje jednocześnie?)
 - Monitoring aktywności API

Zagrożenie 3: Natychmiastowe rozwiązanie umowy

- Dostawca może zablokować dostęp do systemu bez wcześniejszego powiadomienia
- Utrata dostępu do krytycznych danych finansowych
- Brak możliwości prowadzenia księgowości = przestój biznesowy
- Koszty awaryjnej migracji do innego systemu

Zagrożenie 4: Postępowanie sądowe

- Dostawca może wystąpić na drogę sądową o:
 - Zapłatę zaległych opłat licencyjnych
 - Odszkodowanie za straty
 - Koszty postępowania prawnego
- Precedensy: Adobe vs. firmy (miliony USD kar)

Zagrożenie 5: Uszkodzenie reputacji i relacji biznesowych

- Informacja o łamaniu licencji może wycieknąć
- Utrata zaufania partnerów biznesowych
- Problemy z audytami ISO, SOX, compliance
- Negatywny wpływ na wycenę firmy (due diligence przy M&A)

Zagrożenie 6: Brak wsparcia technicznego

- Przy wykryciu naruszenia: brak dostępu do updates, patches, support
- Zagrożenia bezpieczeństwa (nieaktualne oprogramowanie)
- Niemożność zgłoszenia błędów krytycznych

Scenariusz incydentu:

Miesiąc 1: Dostawca SaaS prowadzi automatyczny monitoring

Miesiąc 3: System wykrywa anomalie:

- Logowania z 5 różnych IP jednocześnie
- 5 różnych sesji aktywnych równolegle
- Wysoka aktywność jak dla 1 użytkownika

Miesiąc 4: Dostawca wysyła zawiadomienie o audycie

Miesiąc 5: Audyt potwierdza naruszenie za okres 2 lat

Skutki:

- Kara: 4 licencje × 6,000 PLN/rok × 2 lata × 300% = 144,000 PLN
 - Wymuszenie zakupu 4 dodatkowych licencji: 24,000 PLN/rok
 - Blokada systemu do czasu uregulowania
 - Przerwa księgowości: 2 tygodnie
 - Koszty awaryjnego rozwiązania: 50,000 PLN
- TOTAL: ~220,000 PLN + uszkodzenie reputacji**

Ocena ryzyka - Łamanie licencji:

Prawdopodobieństwo: WYSOKIE (H)

- Łamanie jest jawne i udokumentowane (logi systemowe)
- Dostawcy SaaS coraz częściej prowadzą automatyczne audyty
- Współczesne systemy łatwo wykrywają anomalie użytkownika
- Trend rynkowy: zaostrzanie polityk licencyjnych (Microsoft, Adobe, Salesforce)

Wpływ: WYSOKI (H)

- Potencjalne kary finansowe rzędu 100,000 - 500,000 PLN
- Ryzyko utraty dostępu do krytycznego systemu
- Koszty przestoju i awaryjnej migracji
- Długoterminowe skutki prawne i reputacyjne
- Problemy z compliance i audytami

Poziom ryzyka:  WYSOKIE

3. Łączna ocena ryzyka - Obecna sytuacja

Aspekt	Prawdopodobieństwo	Wpływ	Ryzyko
Brak rozliczalności	Średnie (M)	Wysoki (H)	● WYSOKIE
Łamanie licencji	Wysokie (H)	Wysoki (H)	● WYSOKIE
ŁĄCZNE RYZYKO	-	-	● KRYTYCZNE

Dodatkowe ryzyka:

- Naruszenie RODO (brak możliwości ustalenia, kto przetwarzał dane osobowe)
- Problemy z audytami: ISO 27001, SOX, PCI-DSS
- Naruszenie Kodeksu Pracy (brak możliwości oceny indywidualnej wydajności)

4. Rekomendacja - Rozwiązanie kompromisowe

Strategia: MITYGACJA + optymalizacja kosztów

Nie możemy zaakceptować obecnego stanu (ryzyko krytyczne), ale możemy znaleźć rozwiązanie, które zadowoli zarząd (koszty) i bezpieczeństwo (rozliczalność).

ROZWIĄZANIE WIELOWARSTWOWE

WARIANT A: Licencjonowanie hybrydowe (REKOMENDOWANY) ★

Krok 1: Analiza rzeczywistego użytkowania

Analiza ról w zespole księgowym (5 osób):

- 2 osoby: Codzienne użytkowanie (księgowanie, faktury) → Pełne licencje
- 2 osoby: Okresowe użytkowanie (kontrola, raporty) → Licencje read-only

- 1 osoba: Sporadyczne (zastępstwa, audyt) → Licencja współdzielona z ograniczeniami

Implementacja:

1. Zakup 2 pełnych licencji dla głównych księgowych (4,000 PLN/rok)
2. Zakup 2 licencji read-only dla kontrolerów (1,000 PLN/rok)
 - Większość dostawców SaaS oferuje tańsze licencje tylko do odczytu
 - Koszt: 25-50% pełnej licencji
3. Negocjacja z dostawcą specjalnej licencji „float” dla 1 osoby
 - Argumentacja: compliance, rozliczalność, długoterminowa współpraca
 - Możliwy rabat: 10-30%

Koszty:

- Obecny stan: 1 licencja × 2,000 PLN = 2,000 PLN/rok
- Nowe rozwiązanie:
 - 2 × full (2,000 PLN) = 4,000 PLN
 - 2 × read-only (500 PLN) = 1,000 PLN
 - 1 × float (1,500 PLN z rabatem) = 1,500 PLN
 - TOTAL: 6,500 PLN/rok
- Wzrost kosztów: 4,500 PLN/rok (225%)

Korzyści biznesowe:

-  Pełna rozliczalność wszystkich operacji
-  Zgodność z licencją (unikanie kar 100,000+ PLN)
-  Optymalizacja kosztów (nie 5 × pełna licencja = 10,000 PLN)
-  Możliwość audytów zewnętrznych
-  Segregacja obowiązków (SoD)

WARIANT B: Zmiana dostawcy na tańsze rozwiązanie

Analiza rynku SaaS księgowego:

Dostawca	Model licencji	Koszt/user/ rok	Koszt dla 5 osób
Obecny	Per user	2,000 PLN	10,000 PLN

Alternatywa 1	Płaska opłata	-	8,000 PLN (unlimited users)
Alternatywa 2	Per user tańszy	1,200 PLN	6,000 PLN
Alternatywa 3	Freemium + płatne moduły	800 PLN	4,000 PLN

Implementacja:

- 1. RFP (Request for Proposal) - porównanie 3-5 dostawców**
- 2. Pilot (3 miesiące) - test alternatywnego rozwiązania**
- 3. Migracja danych - przy wsparciu nowego dostawcy**
- 4. Szkolenie zespołu (koszty jednorazowe: 5,000 PLN)**

Koszty migracji:

- Nowy system: 4,000-8,000 PLN/rok**
- Koszty jednorazowe (migracja + szkolenie): 10,000 PLN**
- Break-even: 2-3 lata**
- Oszczędności długoterminowe: 2,000-6,000 PLN/rok**

Ryzyko:

- Przerwy podczas migracji (1-2 tygodnie)**
- Krzywej uczenia dla zespołu**
- Możliwe braki funkcjonalności nowego systemu**

WARIANT C: Rozwiązanie techniczne - SSO + Proxy Logging

Koncepcja: Zachowanie 1 licencji, ale wdrożenie warstwy rozliczalności

Architektura:

Pracownik → SSO (Okta/Azure AD) → Proxy Authenticating → SaaS App
 ↓
Centralne logi audytu

Implementacja:

- 1. Single Sign-On (SSO):**

- Integracja z Azure AD / Okta / Google Workspace
- Każdy pracownik loguje się swoim kontem firmowym
- SSO przekazuje do SaaS jedną wspólną tożsamość, ale:

2. Proxy z logowaniem:

python

Przykładowa logika proxy

def proxy_login(user_email, timestamp):

real_user = get_current_sso_user() # np. jan.kowalski@firma.pl

log_audit(

user=real_user,

action="login_to_finance_app",

timestamp=timestamp,

ip=request.ip

)

Logowanie do SaaS jako "ksiegowosc@firma.pl"

return login_with_shared_credentials()

...

3. ****Centralne logi audytu:****

- Każda akcja w systemie księgowym jest powiązana z rzeczywistym użytkownikiem
- Logi przechowywane w niemutowalnym storage (WORM)
- Retention: minimum 7 lat (wymogi księgowe)

****Koszty:****

- SSO (jeśli nie ma): 3,000-10,000 PLN/rok (Azure AD Business)
- Proxy solution (custom lub gotowe): 5,000-15,000 PLN jednorazowo
- Utrzymanie: 2,000 PLN/rok

****Problem - Zgodność z licencją:****

- ⚠ Nadal technicznie łamiemy licencję "per user"
- ⚠ Ryzyko wykrycia i kar pozostaje

****Wariant C1: Negocjacje z dostawcą****

- Przedstawienie rozwiązania technicznego dostawcy
- Prośba o oficjalną zgodę na taki model użytkowania
- Możliwa dopłata (np. +50% do obecnej licencji = 3,000 PLN/rok)
- Formalna umowa zatwierdzająca rozwiązanie

**WARIANT D: Proceduralne rozwiązanie tymczasowe**

****Dla firm z ograniczonym budżetem - rozwiązanie INTERIM (max 6 miesięcy)****

****Implementacja:****

1. **Dziennik dostępu (logbook):**

...

Data | Godzina | Pracownik | Cel użycia | Podpis

2026-02-23 | 09:00 | Jan Kowalski | Księgowanie FV | JK

2026-02-23 | 11:30 | Anna Nowak | Raport VAT | AN

...

2. **Procedura check-in/check-out hasła:**

- Hasło przechowywane w menedżerze haseł (KeePass/1Password)
- Każdy dostęp wymaga "wypożyczenia" hasła
- Manager haseł loguje, kto i kiedy pobrał credentials

3. **4-eyes principle:**

- Wrażliwe operacje (przelewy >10,000 PLN) wymagają 2 osób
- Jedna wykonuje, druga weryfikuje i potwierdza w logbook

4. **Video recording (opcjonalnie):**

- Nagrywanie ekranu podczas pracy w systemie
- Przechowywanie 30 dni
- RODO: zgoda pracowników + polityka prywatności

****Koszty:****

- Manager haseł korporacyjny: 500 PLN/rok
- Dziennik papierowy/Excel: 0 PLN
- Video recording: 1,000 PLN/rok (software)

****Ograniczenia:****

- ⚠ Nadal łamie licencję
- ⚠ Rozliczalność niepełna (można sfalszować dziennik)
- ⚠ Duży overhead operacyjny
- ⚠ Nieakceptowalne dla audytów zewnętrznych

****Użycie:** Tylko jako rozwiązanie tymczasowe na czas migracji/negocjacji**

**OSTATECZNA REKOMENDACJA**

**Propozycja dla zarządu:**

****Faza 1 (Miesiąc 1-2): Analiza i negocjacje****

1. Przeprowadzenie analizy użytkowania (kto ile korzysta?)
2. Kontakt z obecnym dostawcą:
 - Ujawnienie obecnej sytuacji
 - Negocjacje rabatu za lojalność (3-5 lat umowy)
 - Propozycja modelu hybrydowego (full + read-only)
3. Równolegle: RFP dla 3 alternatywnych dostawców

****Faza 2 (Miesiąc 3): Decyzja****

Wybór między:

- ****Opcja A:**** Pozostanie z obecnym dostawcą + wariant hybrydowy
 - Koszt: 6,500 PLN/rok
 - Wzrost: +4,500 PLN/rok
 - ****Oszczędność vs kara:**** unikanie 100,000+ PLN kar
- ****Opcja B:**** Migracja do tańszego rozwiązania
 - Koszt: 4,000-8,000 PLN/rok + 10,000 PLN migracja
 - Oszczędność długoterminowa: 2,000-6,000 PLN/rok

****Faza 3 (Miesiąc 4-6): Implementacja****

- Wdrożenie wybranego rozwiązania
- Szkolenie zespołu
- Audyt poprawności konfiguracji

**Uzasadnienie biznesowe dla zarządu**

****Argumenty PRO inwestycja:****

| Aspekt | Obecny stan | Po wdrożeniu | ROI |

|-----|-----|-----|-----|
| ****Ryzyko kar licencyjnych**** | 100,000-500,000 PLN | 0 PLN | ****100,000+ PLN**** |
| ****Ryzyko defraudacji**** | Niewykrywalne | Pełna rozliczalność |
****Bezcenne**** |
| ****Audyty zewnętrzne**** | Negatywne | Pozytywne | Możliwość certyfikacji |
|
| ****Compliance**** | Naruszenia RODO, KPR | Zgodność | Unikanie kar UOD |
| ****Koszty roczne**** | 2,000 PLN | 6,500 PLN | +4,500 PLN |

****Kalkulacja ryzyka:****

...

Prawdopodobieństwo kary licencyjnej: 30% w ciągu 3 lat

Średnia kara: 150,000 PLN

Expected Loss = $0.3 \times 150,000 = 45,000$ PLN

Prawdopodobieństwo defraudacji: 10% w ciągu 3 lat

Średnia strata: 50,000 PLN

Expected Loss = $0.1 \times 50,000 = 5,000$ PLN

TOTAL EXPECTED LOSS: 50,000 PLN w 3 lata

Koszt wdrożenia: $4,500 \text{ PLN/rok} \times 3 = 13,500$ PLN

ZYSKOWNOŚĆ: $50,000 - 13,500 = 36,500$ PLN oszczędności

ROI: $(36,500 / 13,500) \times 100\% = 270\%$

Wniosek: Inwestycja w indywidualne licencje zwraca się 3-krotnie przez unikanie ryzyka.

Odpowiedź na pytanie: Czy wymusisz zakup?

TAK, ale inteligentnie:

 **Wymuszam zakup, ale:**

- Nie 5 pełnych licencji (10,000 PLN)
- Tylko 2-4 licencje w modelu hybrydowym (6,500 PLN)
- Z negocjacjami rabatu (możliwe 5,000-6,000 PLN)

- **Lub migracja do tańszego dostawcy (4,000-6,000 PLN)**

✓ Uzasadnienie dla zarządu:

- **"Oszczędność 4,000 PLN/rok vs ryzyko straty 100,000+ PLN to nierozwiał biznesowy"**
- **"Obecny stan uniemożliwia audyty i certyfikacje ISO/SOX"**
- **"Compliance jest wymogiem prawnym, nie opcją"**

✓ Kompromis:

- **Optymalizacja kosztów przez model hybrydowy**
- **Rozłożenie kosztów w czasie (umowa wieloletnia z rabatem)**
- **Możliwość ubiegania się o granty na cyfryzację (dofinansowanie 50%)**

Nie akceptuję rozwiązań proceduralnych (dziennik, współdzielone hasło) jako rozwiązania długoterminowego - to pozorne oszczędności, które generują nieakceptowalne ryzyko.